

Informe Técnico de Seguridad: Cross-Site Scripting (XSS)

Título del Hallazgo

Vulnerabilidad de Cross-Site Scripting (XSS) en el campo de comentarios

Descripción

Durante una evaluación de seguridad ofensiva en un entorno controlado, se identificó una vulnerabilidad de tipo Cross-Site Scripting reflejado en el campo de comentarios de una aplicación web. Esta falla permite que un atacante inyecte código malicioso que se ejecuta directamente en el navegador de otros usuarios, comprometiendo la integridad y confidencialidad de la sesión.

Evidencia Técnica

El hallazgo fue identificado mediante análisis manual utilizando la herramienta Burp Suite en modo de interceptación, junto con observaciones directas en el navegador Firefox utilizando herramientas de desarrollo.

Se utilizó el siguiente payload como prueba de concepto:

```
<script>alert("XSS")</script>
```

Al insertar este código en el campo de comentarios y enviar el formulario, el sistema almacenó y mostró el contenido sin aplicar ningún filtro o sanitización. Al cargar la página de visualización de comentarios, el script se ejecutó automáticamente en el navegador, lo que demostró que el contenido ingresado por el usuario no fue procesado de forma segura.

Para reproducir el comportamiento se debe acceder al formulario de comentarios, insertar el payload en el campo correspondiente, enviar el comentario y luego visualizarlo desde el panel público de comentarios. Al hacer esto, el navegador ejecutará automáticamente el contenido inyectado, mostrando un cuadro de alerta con el texto "XSS".

Este comportamiento confirma que el sistema es vulnerable a ataques de tipo Cross-Site Scripting reflejado y que no cuenta con mecanismos de defensa adecuados en la capa de presentación.

Evaluación de Impacto y Riesgo

Se estimó una puntuación de severidad media según el estándar CVSS v3.1, con un vector de ataque de red, sin requerir privilegios, y con un impacto directo en la confidencialidad y la integridad de los datos del usuario.

Los activos comprometidos incluyen sesiones de usuarios autenticados, cookies, tokens de autenticación y datos personales visibles en el entorno vulnerable. Este tipo de vulnerabilidad puede ser aprovechada por un atacante para robar credenciales, secuestrar sesiones o realizar acciones maliciosas en nombre de la víctima.

El riesgo asociado se clasifica como alto, debido a la posibilidad de explotación remota sin autenticación y al potencial impacto en múltiples usuarios simultáneamente.

Recomendaciones Técnicas

Es fundamental implementar codificación de salida en todos los campos que presenten datos ingresados por el usuario, de modo que los caracteres especiales sean tratados como texto y no como código ejecutable. También se recomienda aplicar validaciones estrictas del lado del servidor para prevenir la inclusión de scripts maliciosos en los formularios.

Adicionalmente, es recomendable configurar una política de seguridad de contenido (Content Security Policy) que limite la ejecución de scripts inline y controle el origen de recursos externos. Esto proporciona una capa adicional de defensa en profundidad.

El uso de frameworks modernos que integran mecanismos de prevención automática de XSS puede ayudar significativamente a reducir la exposición a este tipo de ataques.

Referencias

OWASP XSS Prevention Cheat Sheet

<https://owasp.org/www-community/xss-prevention>

Mozilla Developer Network - Content Security Policy

<https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>

CVSS Calculator

<https://www.first.org/cvss/calculator/3.1>

Reflexión Final

Un informe técnico profesional se distingue por su capacidad de comunicar con precisión, claridad y profundidad tanto el problema como su solución. A diferencia de una alerta técnica que suele limitarse a señalar una falla, este tipo de documento contextualiza el hallazgo, demuestra su validez con evidencia, analiza el impacto y proporciona recomendaciones accionables. El lenguaje, la estructura y la coherencia argumental son esenciales para que tanto los equipos técnicos como la alta dirección comprendan la importancia del hallazgo y actúen en consecuencia.